

HW02 — Bug Report

Student: Lê Thiên Phú (23127244) · **Fork:** <https://github.com/lamTpG/eshop-sut> **Bugs filed on:** the group repository — <https://github.com/dinosauce-285/Software-Testing-G02/issues> **Total confirmed bugs (in-scope):** 14 · **Bonus findings (out of scope):** 2

This is a standalone summary of every confirmed defect found during Domain Testing / BVA across the four assigned features. Each entry includes the GitHub Issue where it was formally reported, with a screenshot attached. Full technical detail, test-case derivation, and execution evidence live in the corresponding feature report under [reports/](#).

Summary table

#	Feature	Sev	Defect	GitHub Issue
1	FR-04	CRIT	Role privilege escalation via <code>PUT /api/users/me</code>	BUG-A-10 #32
2	FR-04	MAJ	Phone regex mismatch (frontend vs. spec)	BUG-A-11 #33
3	FR-04	MAJ	Empty phone blocks unrelated saves	BUG-A-12 #34
4	FR-04	MAJ	Zero server-side validation on name/phone/address	BUG-A-13 #35
5	FR-04	MIN	Silent NULL-coercion on field omission	BUG-A-14 #36
6	FR-08	CRIT	Checkout total directly editable in UI	BUG-B-07 #37
7	FR-08	CRIT	Backend never recalculates <code>total_amount</code>	BUG-B-08 #38
8	FR-08	MAJ	Cart never cleared after successful checkout	BUG-B-09 #39
9	FR-08	MAJ	No cart-size guard — phantom order for an empty cart	BUG-B-10 #40
10	FR-19	CRIT	No role check on admin endpoints	BUG-C-08 #41
11	FR-19	CRIT	No self-deletion guard	BUG-C-09 #42
12	FR-19	MIN	DELETE ignores <code>this.changes</code> (false-positive success)	BUG-C-10 #43
13	FR-11	CRIT	IDOR on <code>GET /api/orders/:id</code>	BUG-D-10 #44
14	FR-11	MAJ	No status color differentiation	BUG-D-11 #45

Severity: **CRIT** = critical (security or spec-core violation) · **MAJ** = major functional defect · **MIN** = minor / contract inconsistency.

FR-04 — Profile Management

#1 — CRIT — Role privilege escalation. `PUT /api/users/me` applies a client-supplied `role` field whenever it's truthy (`server.js` lines 118–129), letting any authenticated user set their own `role` to `"admin"` (TC-31), including hidden inside an otherwise-normal profile update (TC-33). **Issue:** [BUG-A-10 #32](#)

#2 — MAJ — Phone regex mismatch. `Profile.jsx` line 43 requires the first digit to be 1–9 and total length 9–10 digits; the spec requires first digit 0 and 10–11 digits. Every spec-valid phone number is rejected by the UI (TC-11, TC-13, TC-15); the wrong-prefix class is wrongly accepted (TC-23). **Issue:** [BUG-A-11 #33](#)

#3 — MAJ — Empty phone blocks unrelated saves. The buggy regex rejects "", so a user cannot save just their name/address without a valid phone on file (TC-11), even though phone should be optional. **Issue:** [BUG-A-12 #34](#)

#4 — MAJ — Zero server-side validation. on `name`, `phone`, `shipping_address` — every length/format/charset invalid class is silently accepted and persisted by the backend (TC-05–TC-07, TC-17–TC-21). **Issue:** [BUG-A-13 #35](#)

#5 — MIN — Silent NULL-coercion on field omission. When `name`, `shipping_address`, or `phone` is omitted entirely from the JSON payload (TC-08, TC-10, TC-22), the endpoint returns 200 with no crash; the omitted key is bound as `undefined` and node's sqlite3 driver coerces it to SQL `NULL`, silently wiping the existing value instead of leaving it unchanged or rejecting the request. **Issue:** [BUG-A-14 #36](#)

No confirmed defect in: email immutability, auth-state gating, or cross-user isolation.

FR-08 — Checkout

#6 — CRIT — Checkout total directly editable in UI. `Checkout.jsx:110-121` renders a plain `<input type="number">` bound to `editableTotal`, the literal opposite of "không cho phép người dùng chỉnh sửa trực tiếp." **Issue:** [BUG-B-07 #37](#)

#7 — CRIT — Backend never recalculates `total_amount`. `POST /api/checkout` (`server.js:297-309`) inserts the client-submitted `total_amount` verbatim, with no product-price lookup at all — the exact scenario the spec explicitly prohibits (TC-05–TC-15, TC-17). Combined with #6, any user can pay any amount for any cart. **Issue:** [BUG-B-08 #38](#)

#8 — MAJ — Cart never cleared after a successful checkout. `clearCart()` (defined in `CartContext.jsx:18`) is never invoked in `Checkout.jsx`'s `handleCheckout` — confirmed even on the nominal happy path (TC-01). **Issue:** [BUG-B-09 #39](#)

#9 — MAJ — No cart-size guard. The backend never reads or validates the `items` array; an order is created for an empty cart (TC-16), stacking with #7 to allow a fully attacker-priced "phantom" order for zero products (TC-17). **Issue:** [BUG-B-10 #40](#)

No confirmed defect in: auth-state gating, order-owner identity/cross-user isolation, or the coupon-applied path introducing any additional breakage. The checkout page being viewable while logged out was initially flagged but corrected — the spec only requires the checkout action be blocked, which the 401 response already enforces (see AI Gap Analysis in [MainReport.md](#)).

FR-19 — User Management (Admin)

#10 — CRIT — No role check on admin endpoints. `GET /api/admin/users` and `DELETE /api/admin/users/:id` apply only `authenticateToken`, never inspecting `req.user.role`. Any authenticated account — including one carrying an arbitrary garbage role string — can list all users and delete

any user, including the sole admin account (TC-04, TC-05, TC-12, TC-13). Confirmed reachable through the real admin panel UI, not just direct API calls (TC-15). **Issue:** [BUG-C-08 #41](#)

#11 — CRIT — No self-deletion guard. The DELETE handler never compares `req.params.id` to `req.user.id`; an admin can delete their own currently-logged-in account, directly violating the spec's explicit exception clause (TC-07). Confirmed trivially triggerable via a normal UI click, with no confirmation dialog (TC-14). **Combined with #10**, a plain `user`-role account can delete the system's only admin account — a full administrative lockout. **Issue:** [BUG-C-09 #42](#)

#12 — MIN — DELETE ignores `this.changes`. Deleting a non-existent (999999), negative (-1), zero (0), or non-numeric ("abc") id all return a false-positive 200 "User deleted" with zero actual effect. **Issue:** [BUG-C-10 #43](#)

No confirmed defect in: password exposure (never leaked in any GET response), or the legitimate admin-deletes-other-user path, which works correctly.

FR-11 — Order History (Mobile)

#13 — CRIT — IDOR on GET `/api/orders/:id`. The endpoint (`server.js:344-349`) has no `authenticateToken` middleware and its query has no `user_id` filter — any caller, authenticated or not, can fetch any order by id and see another user's `total_amount`, `status`, and `shipping_address` (TC-10). Directly contradicts the spec's first line and stands in stark contrast to `/my-orders`, which correctly scopes to the caller. **Issue:** [BUG-D-10 #44](#)

#14 — MAJ — No status color differentiation. No status-keyed styling exists in `frontend-mobile/App.js`; all 5 statuses render in identical default text color (TC-11), contradicting the spec's explicit color-differentiation requirement. Status *translation* to Vietnamese, by contrast, is fully correct. **Issue:** [BUG-D-11 #45](#)

No confirmed defect in: `/my-orders` auth/scoping, status translation, cancel-button gating, or the existence-boundary handling of GET `/orders/:id` itself (the endpoint's only failure is the missing ownership check, #13).

Bonus findings (outside the 4 assigned features' scope)

These were surfaced during testing but are not counted in the 14 in-scope bugs above, since they belong to features outside this student's assignment. Reported here for completeness, not filed as GitHub Issues.

Sev	Defect	How found	Owning FR
CRIT	SAVE10 coupon math inversion — percent formula treats <code>discount_value</code> (10) as a whole number, so a "10% off" coupon multiplies the total ~10× (58,000,000 → 580,000,000)	Execution of FR-08 TC-18	FR-09 (not assigned)
MAJ	Mobile order-history staleness — admin status changes never refresh the user's history screen until they cancel/place an order	Exploratory testing	FR-11/FR-20 (sync — not a Domain Testing finding)

Full reproduction steps, boundary derivations, and executed test-case evidence for every bug above are in the corresponding feature report: [reports/FR-04-ProfileManagement/](#), [reports/FR-08-Checkout/](#), [reports/FR-19-UserManagement/](#), [reports/FR-11-OrderHistory-Mobile/](#).